

CÓMO REALIZAR EVALUACIONES DE RIESGO DE TERCEROS Y PROVEEDORES

Guía práctica de diligencia debida, contratos, evidencia, monitoreo, incidentes y seguridad de la cadena de suministro

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

La seguridad humana y la equidad son lo primero. Este manual está destinado a usos legales, autorizados y defensivos. Las evaluaciones de proveedores deben ser justas, basadas en evidencia, proporcionales al riesgo y respetuosas de la confidencialidad.

1. Propósito y resultados

- Identificar cómo un proveedor, servicio, contratista, producto de software, plataforma de nube o proveedor de IA puede afectar a la organización.
- Decidir si la relación es aceptable, requiere corrección, necesita mejores cláusulas o no debe continuar.
- Crear un registro repetible de alcance, evidencia, hallazgos, decisiones, responsables y fechas de revisión.
- Aplicar mayor diligencia a relaciones de alto riesgo sin crear barreras innecesarias para proveedores de bajo riesgo.

2. Gobierno del programa

- Asignar patrocinio ejecutivo y responsabilidades claras entre seguridad, privacidad, asuntos legales, compras, cumplimiento, negocio y tecnología.
- Definir metodología, niveles de riesgo, evidencia, escalamiento, autoridad de excepciones y frecuencia de revisión.
- Mantener independencia entre el patrocinador empresarial y quien aprueba riesgo residual material.
- Medir oportunidad, evaluaciones vencidas, hallazgos críticos, concentración e incidentes.

3. Inventario de proveedores

- Registrar nombre legal, empresa matriz, servicio, propietario, contrato, países, datos, integraciones, subcontratistas, renovación y terminación.
- Incluir software gratuito, código abierto, aplicaciones de marketplace, consultores, intermediarios de datos, servicios de IA y tecnología no autorizada.
- Relacionar proveedores con servicios empresariales, sistemas, datos, regulaciones y continuidad.
- Marcar correctamente proveedores inactivos, duplicados, adquiridos o terminados.

4. Clasificación inicial

- Clasifique antes de enviar un cuestionario extenso.
- Considere sensibilidad de datos, acceso privilegiado, conectividad, autoridad transaccional, criticidad, usuarios, geografía, IA, subcontratistas y facilidad de reemplazo.
- Use una puntuación de riesgo inherente sencilla con juicio profesional y excepciones documentadas.
- No considere a un proveedor pequeño como bajo riesgo solamente por su tamaño.

5. Alcance de la evaluación

- Defina producto, servicio, entorno, flujo de datos, interfaces, ubicaciones y contrato.
- Indique si la revisión cubre toda la empresa, un producto, un servicio alojado, una región o un tratamiento específico.
- Identifique exclusiones y sus razones.

- Defina fechas de evidencia y rechace evidencia obsoleta.

6. Evidencia de diligencia debida

- Prefiera evidencia sobre respuestas sin respaldo.
- La evidencia puede incluir informes SOC, certificados ISO, resúmenes de pruebas, políticas, diagramas, vulnerabilidades, continuidad, ejercicios de incidentes, privacidad y desarrollo seguro.
- Verifique alcance, período, emisor, cualificaciones, excepciones, respuestas y controles complementarios del cliente.
- Proteja la evidencia confidencial del proveedor.

7. Dominios de seguridad

- Gobierno y gestión de riesgos.
- Identidad, acceso privilegiado y autenticación.
- Protección, cifrado, retención y eliminación de datos.
- Seguridad de red y nube.
- Desarrollo seguro, vulnerabilidades y cadena de software.
- Registros, monitoreo, detección y respuesta.
- Continuidad, recuperación y resiliencia.
- Privacidad, regulación y contratos.
- Subcontratistas y cuartas partes.
- Sistemas de IA, modelos, agentes, datos de entrenamiento, RAG y decisiones automatizadas.

8. Diseño del cuestionario

- Pregunte únicamente lo que pueda cambiar una decisión o requisito.
- Use preguntas condicionales.
- Solicite evidencia clara para afirmaciones materiales.
- Evite copiar cientos de controles sin explicar su aplicación.
- Permita explicar controles compensatorios y planes de corrección.
- Registre fuente, marco, evidencia, conclusión y vencimiento.

9. Revisión de informes SOC y certificaciones

- Confirme que cubren el servicio comprado.
- Revise período, opinión, limitaciones, exclusiones, excepciones, subservicios y controles del cliente.
- No trate un informe limpio como prueba de que todos los riesgos están cubiertos.
- Confirme la vigencia y acreditación cuando corresponda.
- Solicite cartas puente o evidencia reciente cuando haya terminado el período.

10. Riesgo de nube, software y código abierto

- Identifique alojamiento, regiones, tenencia, acceso administrativo, copias, cifrado, registros y responsabilidades del cliente.
- Revise SBOM cuando corresponda, dependencias, firma de código, integridad de versiones y divulgación de vulnerabilidades.
- Evalúe la velocidad de corrección de vulnerabilidades críticas.
- Identifique componentes sin soporte o bibliotecas abandonadas.
- Documente las obligaciones de configuración del cliente.

11. Riesgo de proveedores y servicios de IA

- Identifique modelos, proveedores, usos de datos, retención de instrucciones, entrenamiento, subprocesadores, ubicación, controles, supervisión e incidentes.
- Determine si información confidencial o personal puede mejorar modelos compartidos.
- Evalúe inyección de instrucciones, fuga de datos, agentes inseguros, herramientas, autorización RAG, actualizaciones y confiabilidad.
- Exija transparencia sobre cambios materiales.
- Defina usos prohibidos y aprobaciones para decisiones de alto impacto.

12. Controles contractuales y de compras

- Convierta decisiones importantes en obligaciones exigibles.
- Aborde seguridad, privacidad, confidencialidad, ubicación, subcontratistas, auditoría, notificación, cooperación, vulnerabilidades, continuidad, seguros, registros, eliminación y terminación.
- Defina niveles de servicio medibles.
- Exija que obligaciones relevantes se transmitan a subcontratistas.
- No dependa de un cuestionario si el contrato no exige los controles prometidos.

13. Hallazgos y calificación

- Redacte condición, riesgo, evidencia, impacto y acción.
- Separe riesgo inherente, eficacia, riesgo residual y aceptación.
- Use severidad consistente y considere explotación, sensibilidad, impacto, obligaciones y concentración.
- No convierta cada brecha en riesgo alto.
- Registre incertidumbre cuando falte evidencia.

14. Corrección y excepciones

- Asigne responsable, acción, fecha, evidencia y revisión.
- Use medidas provisionales cuando la corrección permanente tarde.
- Escalone acciones de alto riesgo vencidas.
- Exija aceptación formal de riesgo residual material.

- Defina vencimiento de excepciones y reevalúe.
- Cierre hallazgos solamente después de revisar evidencia.

15. Monitoreo continuo

- Use calificaciones externas como señales, no como conclusión final.
- Vigile brechas, propiedad, adquisiciones, litigios, certificados, vulnerabilidades, interrupciones, ubicación, subcontratistas y cambios.
- Reevalúe después de incidentes, cambios de arquitectura, ampliación de datos, nuevas integraciones o renovación.
- Mantenga frecuencia proporcional al riesgo.

16. Incidentes de proveedores

- Mantenga contactos y escalamiento actuales.
- Defina plazos y datos de notificación en contratos.
- Coordine contención, evidencia, análisis regulatorio, comunicaciones, recuperación y lecciones.
- Determine si debe suspender acceso, tokens, integraciones o transferencias.
- Valide las acciones correctivas del proveedor.

17. Retiro y terminación

- Desactive cuentas, tokens, integraciones, VPN, claves, certificados y acceso administrativo.
- Recupere activos y confirme devolución o eliminación segura de datos.
- Conserve registros legales y de auditoría.
- Transfiera conocimiento, configuraciones y dependencias.
- Retire al proveedor de inventarios solamente después de verificar el cierre.

18. Informes y métricas

- Informe población por nivel, estado, revisiones vencidas, hallazgos, riesgos aceptados, incidentes, concentración y dependencias.
- Muestre tendencias.
- Separe riesgos del proveedor y responsabilidades del cliente.
- Presente decisiones y exposición, no solo cuestionarios completados.

19. Plan de 30, 60 y 90 días

- Días 1 a 30: definir gobierno, inventariar proveedores críticos, crear niveles, identificar relaciones vencidas y establecer cláusulas mínimas.
- Días 31 a 60: ejecutar evaluaciones basadas en riesgo, centralizar evidencia, crear flujos de hallazgos y excepciones, e identificar concentración y cuartas partes.
- Días 61 a 90: implementar monitoreo, ejercicios, controles de renovación, métricas y revisiones de calidad.

20. Flujo práctico de evaluación

1. Recibir la solicitud e identificar al propietario empresarial.
2. Completar la clasificación de riesgo inherente.
3. Definir alcance y evidencia.
4. Recopilar y revisar evidencia.
5. Entrevistar al proveedor cuando existan dudas materiales.
6. Documentar hallazgos y riesgo residual.
7. Acordar correcciones y controles contractuales.
8. Obtener aprobación o aceptación.
9. Registrar monitoreo y reevaluación.
10. Reevaluar en la renovación o después de cambios materiales.

21. Criterios de nivel de riesgo

Nivel	Características	Revisión
Crítico	Acceso privilegiado, datos muy sensibles, operación esencial, autoridad transaccional o concentración	Evaluación completa, contrato, aprobación ejecutiva y revisión anual o por evento
Alto	Datos sensibles, integración productiva, servicio importante o subcontratistas relevantes	Revisión detallada y reevaluación anual
Moderado	Datos confidenciales limitados o dependencia moderada	Cuestionario enfocado y revisión periódica
Bajo	Sin datos sensibles ni conectividad y fácil reemplazo	Verificación básica

22. Ejemplo de hallazgo

Elemento	Ejemplo
Condición	El proveedor no exige MFA para administración privilegiada de producción.
Evidencia	Política de acceso y entrevista de julio de 2026.
Riesgo	Una contraseña robada podría permitir acceso no autorizado y exposición de datos.
Acción	Implementar MFA resistente a phishing y proporcionar evidencia.
Control provisional	Restringir por red, monitorear accesos y rotar credenciales.
Responsable / plazo	Líder de seguridad del proveedor / 60 días

23. Lista de verificación

☐ Registro de inventario completado

- ☐ Propietario empresarial y contractual identificados
- ☐ Nivel de riesgo inherente aprobado
- ☐ Alcance y flujo de datos documentados
- ☐ Evidencia vigente y aplicable
- ☐ Alcance y excepciones SOC/ISO revisados
- ☐ Seguridad, privacidad, continuidad e incidentes evaluados
- ☐ Subcontratistas y concentración revisados
- ☐ Riesgo de IA revisado cuando corresponda
- ☐ Cláusulas contractuales aprobadas
- ☐ Hallazgos asignados y controlados
- ☐ Riesgo residual aceptado por autoridad
- ☐ Monitoreo y reevaluación programados
- ☐ Requisitos de retiro documentados

24. Referencias oficiales

- NIST SP 800-161 Rev. 1, Cybersecurity Supply Chain Risk Management Practices: <https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final>
- NIST SP 1326, C-SCRM Due Diligence Assessment Quick-Start Guide: <https://csrc.nist.gov/pubs/sp/1326/final>
- NIST Cybersecurity Framework 2.0: <https://www.nist.gov/cyberframework>
- CISA Supply Chain Resources: <https://www.cisa.gov/topics/cyber-threats-and-advisories/information-and-communications-technology-supply-chain-security>
- ISO/IEC 27036-1:2021 Supplier Relationships: <https://www.iso.org/standard/82905.html>
- ISO/IEC 27036-2:2022 Supplier Relationship Requirements: <https://www.iso.org/standard/82060.html>
- ISO/IEC 27036-3:2023 Hardware, Software, and Services Supply Chain Security: <https://www.iso.org/standard/82890.html>

Licencia

Copyright © 2026 Alberto (Al) Leiva. Distribuido bajo la licencia CC BY-NC-SA 4.0.